

FedShield-ID

1. 🚩 FedShield-ID?

FedShield-ID is a Privacy-First Identity Trust Platform for Banking Networks.

Traditional security asks:

❌ *"Is this single transaction fake?"*

FedShield-ID continuously asks:

✅ *"Can we trust this user's identity right now?"*

It computes a **real-time Trust Score (0 to 100)** for every user based on 10 signals—such as how they type, their mouse movements, device health, location drift, SIM card history, and document integrity. High-trust users enjoy frictionless login, while risky sessions trigger step-up verification or immediate blocks.

🚨 2. The Current Problem in Banking

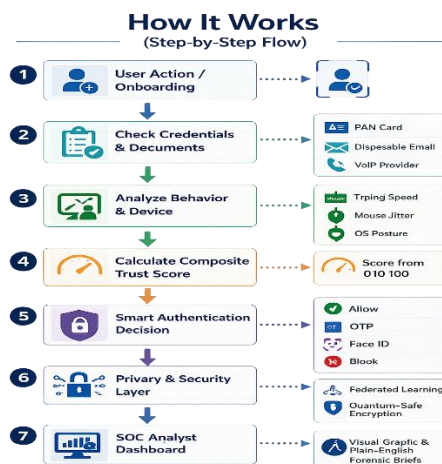
1. **Banks Cannot Share Customer Data:** Due to strict data privacy laws (GDPR, DPDP, RBI), Bank A cannot send customer data to Bank B. Scammers exploit this data isolation to create synthetic identities across multiple banks.
2. **Easy-to-Bypass Passwords & OTPs:** Phishing and SIM-swapping allow attackers to easily steal OTPs and hijack accounts.
3. **Black-Box AI:** Traditional machine learning flags transactions without explaining *why*, making human auditing difficult.
4. **Future Quantum Threats:** Current encryption methods (RSA, ECDH) will become vulnerable when quantum computers arrive.
5. **Insider Threats & SIM Swaps:** Standard monitoring ignores internal employee data dumps or recoveries initiated right after a SIM swap.

💡 3. The Proposed Solution (FedShield-ID)

- **Collaborative AI Without Data Sharing (Federated Learning):** Banks (Bank A, Bank B, Bank C) train AI locally. Only mathematical updates are shared, keeping raw customer data 100% private inside each bank.
- **Math-Backed Privacy Protection (Differential Privacy):** Injects Laplacian noise into model updates so no one can reverse-engineer personal customer records.

- **Quantum-Safe Encryption (Post-Quantum Cryptography):** Uses **Crystals-Kyber-768** key exchange to secure inter-bank model updates against future quantum decryption.
- **Continuous 10-Factor Trust Score (0 to 100):** Dynamically evaluates user actions and device health to update trust continuously.
- **Smart Adaptive Authentication:**
 - **Score > 90:** Frictionless Login.
 - **Score 70–90:** Standard OTP.
 - **Score 50–70:** Step-Up MFA Challenge.
 - **Score 20–50:** Live Face Verification.
 - **Score < 20:** Blocked Instantly.
- **Clear Explanations (Explainable AI & GenAI):** Uses **SHAP** bar charts to highlight exact risk contributors and generates plain-English audit briefs.
- **Visual Fraud Ring Detection (Knowledge Graph):** Highlights interactive graphs when multiple fake accounts share the same device or IP address.

4. How It Works (Step-by-Step Flow)



5. Technology Stack at a Glance

- **Backend:** Python 3.10+, FastAPI (Async Server), SQLAlchemy ORM.
- **Machine Learning & AI:** Scikit-Learn (SGD & Random Forest), SHAP (Explainable AI), NumPy, Pandas.

- **Cryptography:** Simulated Crystals-Kyber-768 (PQC KEM), AES-256-GCM, RSA, ECDH.
- **Database:** SQLite (Local Prototype) & PostgreSQL (Production Docker).
- **Frontend:** React 18, Vite, Tailwind CSS, Chart.js, Lucide Icons.
- **Deployment:** Docker & Docker Compose.

6. Key Innovations & Impact

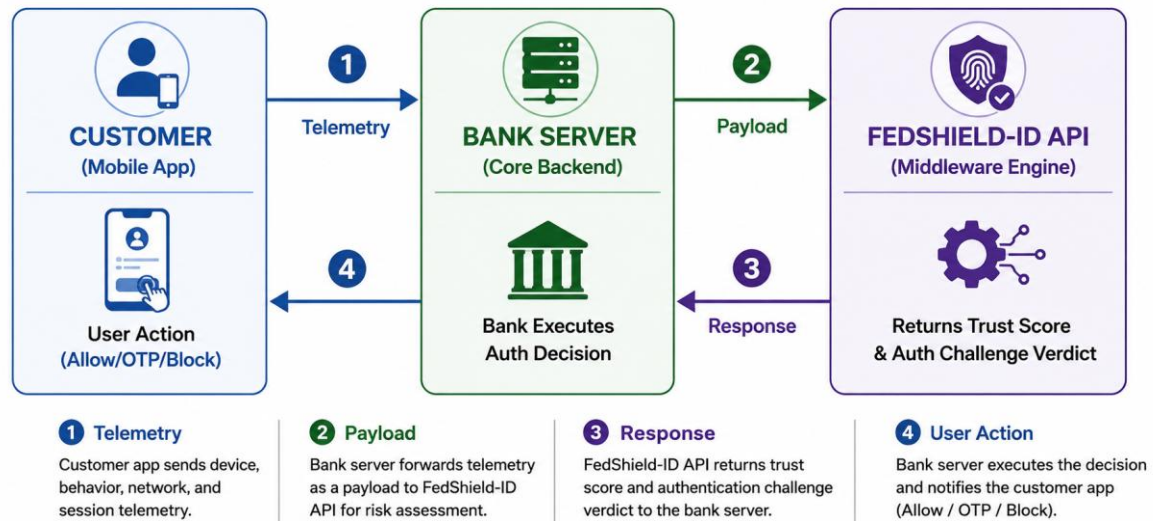
1. **Zero Data Pooling:** Multiple banks train shared AI models without sharing raw customer PII.
2. **Post-Quantum Security:** Ready for next-generation quantum cybersecurity standards.
3. **Frictionless Experience:** Good customers move smoothly; only high-risk sessions get challenged.
4. **Transparent AI:** Security teams see exact mathematical reasons behind every block decision.
5. **Graph Collusion Detection:** Catches multi-account money laundering rings using shared hardware footprints.

7. Phases of Development

1. **Phase 1 (Architecture):** Designed the 10-factor trust scoring engine and adaptive authentication rules.
2. **Phase 2 (Core ML & XAI):** Built machine learning classifiers, synthetic data generator, and SHAP explainability.
3. **Phase 3 (Federated Learning & DP):** Built multi-bank node simulation (Bank A, B, C) with Differential Privacy noise.
4. **Phase 4 (Post-Quantum Security):** Built Crystals-Kyber-768 key encapsulation and cryptographic benchmark tools.
5. **Phase 5 (FastAPI & Database):** Built REST API routes, live transaction streaming, and database models.
6. **Phase 6 (React Dashboard):** Built a dark neon glassmorphism dashboard with live charts and SVG knowledge graphs.
7. **Phase 7 (Containerization & Testing):** Packaged the app into Docker Compose and validated all attack simulation scenarios.

Real-World Scenario: How FedShield-ID Operates Between the Customer and the Bank

Consider a real-world scenario where a customer (**Amaan**) opens their mobile banking application to transfer **\$1,000**.



Step-by-Step Operational Flow

1 Step 1: Customer Action & Background SDK Capture

- **Customer Action:** Amaan opens the banking app, inputs credentials, and clicks *"Transfer \$1,000"*.
- **Background SDK:** Embedded silently inside the bank's mobile application, the lightweight **FedShield-ID SDK** automatically collects non-PII telemetry:
 - **Keystroke Dynamics:** Typing speed and cadence.
 - **Touch / Mouse Jitter:** Screen touch standard deviation (distinguishing human touch from automated bot scripts).
 - **Device Posture:** Validates if the phone is authentic or a rooted/emulated bot environment.
 - **Location & Network:** Current IP address, geolocation drift, and VPN proxy detection.

2 Step 2: Bank Backend Calls the FedShield-ID API Layer

- Immediately upon the customer clicking *"Transfer"*, the bank's core server makes a microsecond API call to the FedShield-ID middleware:
POST <https://api.fedshield.bank.com/v1/predict>

API Request Payload Example:

json

```
{  
  
  "customer_id": "CUST_9821",  
  
  "amount": 1000.0,  
  
  "device_id": "DEV_IPHONE_15",  
  
  "typing_speed": 135.2,  
  
  "mouse_jitter": 1.82,  
  
  "distance_from_home": 12.5,  
  
  "sim_swap_last_72h": false  
}
```

3 Step 3: Real-Time Trust Evaluation (< 15 Milliseconds)

The FedShield-ID API Layer instantly evaluates the payload across 10 security dimensions:

- ❌ Is typing speed unnaturally fast (>300\$ wpm)? *(No, normal human speed)*
- ❌ Was a SIM Swap detected in the last 72 hours? *(No)*
- ❌ Has geolocation drifted by over 1,000 km in minutes? *(No, only 12 km drift)*
- ❌ Is the hardware signature associated with a headless browser? *(No)*

Outcome: Computes a **Composite Identity Trust Score = 94 / 100 (High Trust)**.

4 Step 4: API Returns Verdict to Bank Server

The FedShield-ID API returns a response containing the score, risk level, and required authentication challenge:

API Response Payload Example:

```
json  
  
{  
  
  "trust_score": 94.0,
```

"risk_level": "Trusted",

"auth_action": "ALLOW_FRICTIONLESS",

"reason": "Biometric, device, and location telemetry match customer profile history."

}

5 Step 5: Action Executed on the Customer's Device

Based on the **Trust Score**, the platform dynamically executes the appropriate authentication rule:

Composite Trust Score	Risk Level	API Auth Verdict	Customer Experience
90 – 100	Trusted	Allow Frictionless	Transaction completes instantly without unnecessary OTP prompts.
70 – 90	Low Risk	Prompt Standard OTP	Prompts for a standard SMS/Email One-Time Password.
50 – 70	Medium Risk	Step-Up MFA	Prompts for an Authenticator PIN or Fingerprint scan (e.g. minor location deviation).
20 – 50	High Risk	Live Face Verification	Opens phone camera for Live Biometric Face Matching (e.g. recent SIM swap indicator).
< 20	Critical Threat	Block Access	Transaction blocked instantly; Security Operations Center (SOC) is alerted.



6. Inter-Bank Collaboration (How Data Privacy is Maintained)

Key Question: *How do multiple banks collaborate without leaking private customer data?*

- **Zero Data Pooling:** Bank A (e.g., Chase) and Bank B (e.g., Citi) **never share raw customer names, PAN numbers, or transaction logs.**
- **Asynchronous Nightly Federated Learning:**
 1. Bank A trains an AI model on its local database.

2. Bank A adds mathematical noise (**Differential Privacy**) so individual database records cannot be reconstructed.
 3. Bank A encrypts the model parameters using **Crystals-Kyber-768 (Post-Quantum Cryptography)**.
 4. Encrypted model math values are sent to the central aggregator (**FedAvg**).
- **Result:** All banks continuously benefit from shared fraud intelligence without ever exposing sensitive customer data.

Executive Summary & Project Conclusion

FedShield-ID is a **Privacy-First Identity Trust Platform** designed for banking networks and financial consortia.

● The Problem

Modern banks face severe threat vectors—including synthetic identity fraud, SIM-swap account takeovers, credential-stuffing bot attacks, and insider data theft. At the same time, strict privacy regulations (**GDPR, DPDP Act, RBI Guidelines**) prevent banks from sharing raw customer data (PII) to catch cross-bank fraudsters. As a result, banks operate in isolated data silos, which cybercriminals exploit to commit multi-bank fraud undetected.

● The Solution

FedShield-ID shifts the security paradigm from **reactive transaction monitoring** ("*Is this single transaction fake?*") to **continuous zero-trust identity evaluation** ("*Can this identity be trusted right now?*").

Key solution components include:

1. **Privacy-Preserving Federated Learning (FedAvg):** Multiple banks (Bank A, B, C) collaboratively train AI models on local servers without ever sharing or pooling raw customer data.
2. **Differential Privacy (DP):** Injects Laplacian noise into model parameter updates under a strict privacy budget (ϵ), mathematically guaranteeing that customer database records cannot be reverse-engineered.
3. **Post-Quantum Cryptography (PQC):** Uses simulated **CRYSTALS-Kyber-768 Key Encapsulation (KEM)** & AES-256-GCM to encrypt inter-bank model payloads against future quantum computing decryption attacks.

4. **Continuous 10-Factor Trust Engine:** Evaluates 10 real-time signals—such as keystroke dynamics, mouse jitter, device posture, location drift, SIM swaps, and insider threats—to derive a composite **Trust Score (0–100)**.
5. **Adaptive Risk-Based Authentication (RBA):** Maps the Trust Score directly to dynamic security rules—granting frictionless login for trusted sessions ($>90\%$) while triggering OTP, Step-Up MFA, Live Face Verification, or Access Blocks for elevated risks.
6. **Explainable AI (SHAP) & GenAI Forensics:** Eliminates black-box AI risks by rendering visual SHAP feature attributions and natural-language incident briefs for SOC analysts.
7. **Graph-Based Collusion Detection:** Uses an SVG Knowledge Graph to expose shared hardware fingerprints, VPN nodes, and multi-account money laundering rings.

Technology Stack

- **Backend:** Python 3.10+, FastAPI (Async REST Server), SQLAlchemy ORM, SQLite / PostgreSQL.
- **Machine Learning & XAI:** Scikit-Learn (SGD & Random Forest Classifiers), NumPy, Pandas, SHAP.
- **Cryptography:** Simulated CRYSTALS-Kyber-768 KEM, Python Cryptography (AES-256-GCM, RSA, ECDH).
- **Frontend:** React 18, Vite, Tailwind CSS, Chart.js, Lucide Icons.
- **Deployment:** Docker & Docker Compose.

Project Conclusion & Key Takeaways

1. **Zero-Trust Identity Over Static Checks:** FedShield-ID proves that evaluating continuous identity trust provides vastly superior security compared to legacy, isolated transaction checks.
2. **Full Privacy & Regulatory Compliance:** Eliminating central data lakes allows banks to comply 100% with strict data residency laws (RBI, GDPR, DPDP) while maintaining collaborative AI fraud detection.
3. **Future-Proof Quantum Readiness:** Integrating post-quantum key encapsulation (Kyber-768) ensures inter-bank communications remain secure against future quantum decryption threats.
4. **Superior Customer Experience:** High-trust customers enjoy smooth, frictionless banking, while security step-ups are triggered only when risk metrics demand it.

5. **Actionable Security Operations:** Explainable AI (SHAP) and interactive Knowledge Graphs empower SOC teams to make rapid, transparent, and accurate audit decisions.

NOTE

Final Conclusion Statement:

FedShield-ID redefines financial security by bridging the gap between absolute customer privacy and collaborative fraud prevention.

"Trust Every Identity. Verify Only When Risk Demands."